



MASTG

Backgrounded

- MASTG-TEST-0293: `setSecure` Not Used to Prevent Screenshots in SurfaceViews
- MASTG-TEST-0294: `SecureOn` Not Used to Prevent Screenshots in Compose Dialogs
- MASTG-TEST-0315: Sensitive Data Exposed via Notifications
- MASTG-TEST-0316: App Exposing User Authentication Data in Text Input Fields
- MASTG-TEST-0320: WebViews Not Cleaning Up Sensitive Data
- MASTG-TEST-0334: Native Code Exposed

L2

ANDROID

MASWE-0054

TEST



# MASTG-TEST-0315: Sensitive Data Exposed via Notifications

## Overview

This test verifies that the app correctly handles notifications, ensuring that sensitive information, such as personally identifiable information (PII), one-time passwords (OTPs), or other sensitive data, like health or financial details, is not exposed.

On Android 13 and higher, apps targeting API level 33 or above must request the runtime permission `POST_NOTIFICATIONS` to send notifications. Below API level 33, this permission is not required. For testing purposes, we consider the value of the app's `minSdkVersion` because it indicates the lowest Android version on which the app can run.

Notifications can be created using the `setContentTitle` and `setContentText` methods of `Notification.Builder` or `NotificationCompat.Builder`.

Notification usage should not expose sensitive information that could be disclosed accidentally, e.g., through shoulder surfing or when sharing the device with another person.

## Steps

- Use *Reverse Engineering Android Apps* to reverse engineer the app.
- Use *Obtaining Information from the AndroidManifest* to obtain the `AndroidManifest.xml` file.
- Use *Static Analysis on Android* to look for the declaration of the `POST_NOTIFICATIONS` permission and the `minSdkVersion` in the `AndroidManifest.xml` file.
- Use *Static Analysis on Android* to look for references to notification APIs such as `NotificationCompat.Builder`, `setContentTitle`, or `setContentText` in the app's source code.

## Observation

The output should contain:

- the `POST_NOTIFICATIONS` permission, if declared,
- the value of `minSdkVersion`, and
- a list of locations where notification APIs are used.

## Evaluation

The test case fails if the app exposes any sensitive data in any notifications and either:

- `minSdkVersion` is 33 or higher and the `POST_NOTIFICATIONS` permission is declared in the manifest file, or
- `minSdkVersion` is 32 or lower, regardless of whether the `POST_NOTIFICATIONS` permission is declared.

**Why `minSdkVersion` and not `targetSdkVersion` ?**: Using `minSdkVersion` ensures the test accounts for the **least secure environment** in which the app can operate, which is what determines the real exposure risk.

`targetSdkVersion` only influences how the app behaves on newer Android versions and how the system enforces newer platform restrictions. It does not change the behavior of older Android versions. As a result, an app with a high `targetSdkVersion` but a low `minSdkVersion` must still be evaluated against the security guarantees, or lack thereof, of those older versions.

## Best Practices

MASTG-BEST-0027: Preventing Sensitive Data Exposure in Notifications

## Demos

MASTG-DEMO-0078: App Leaking Sensitive Data via Notifications